

be considered a simulation of an attack by an external hacker, who has gained illegitimate access to an organisation's network infrastructure documents.

The purpose of pen testing

The key goal of a pen test is to identify weak spots in an organisation's security posture, as well as measure the compliance of its security policy, test the staff's awareness of security issues, and determine whether and how vulnerable the organisation is to security disasters.

A penetration test can also highlight weaknesses in a company's security policies. For instance, although a security policy focuses on preventing and detecting an attack on an enterprise's systems, that policy may not include a process to expel a hacker.

The various stages in the penetration testing process

The planning phase

1. The scope and strategy of the assignment is determined.
2. Existing security policies and standards are used for defining the scope.

The discovery phase

1. As much information as possible about the system is collected, including data in the system, user names and even passwords. This is also called fingerprinting.
2. The ports are scanned and probed.
3. Vulnerabilities of the system are checked.

The attack phase

In this phase, the various vulnerabilities are found and exploited. You need the necessary security privileges to exploit the system.

The reporting phase

1. A report must contain detailed findings.
2. It must list the risks of the vulnerabilities found, and their

impact on the business.

3. Recommendations and solutions, if any, must be given.

Penetration testing tools

There is a wide variety of tools that are used in penetration testing, some of which are listed below.

1. **Nmap:** This is used to do port scanning, OS identification, tracing the route and for vulnerability scanning.
2. **Nessus:** This is a traditional network based vulnerability testing tool.
3. **Pass-The-Hash:** This tool is mainly used for password cracking.

The need for penetration testing

Penetration testing assesses the effectiveness of your existing security controls in a real-world scenario, when a skilled human actively tries to hack in. While automated testing can identify some cybersecurity issues, true penetration testing considers the business's vulnerability to manual attack too. After all, bad actors aren't going to stop their attacks just because the standard automated test doesn't identify a vulnerability.

Consistent automated and manual testing can determine infrastructure, software, physical and even personnel weaknesses and help your business develop strong controls. For much the same reason you go to a healthcare provider for an annual wellness check, it makes sense to turn to highly trained security consultants to carry out your security testing. While you might say you're perfectly healthy, a doctor will run some tests to check if there are any dangers you may not even be aware of yet.

Similarly, the people who put together your security program,

maintain and observe it on a daily basis. They may not have the objectivity needed to identify security flaws, understand the level of risk for your organisation, and help address and fix critical issues.

Some of the major reasons for using pen testing are:

1. Shows your security team, in real-time, how attack vectors impact the organisation.
2. A pen test uncovers major vulnerabilities
3. Pen tests prioritise your vulnerabilities into low, medium, and high risk.
4. Gives you an opportunity to fix vulnerabilities.
5. Identifies problems you didn't know existed.
6. Identifies security controls that you need to implement.
7. Reveals any poor internal security processes.
8. Trains your security team on how to better detect and respond to threats.
9. Improves business continuity.
10. Protects your most critical data.

Key takeaways

When it comes to your data, your networks, your business and your people, one thing matters most: real-world security. The value you put on a penetration test is mainly dependent on who you trust as a partner, what degree of freedom you give the tester to operate within and how they relate their reporting to your organisation's needs. Penetration testing is a bit like going to get an MRI — it's never something you want to do (and you hope the results come back negative), but you do it because you need peace of mind and you want to know what things look like in the real world. **END** 🐧

By: Neetesh Mehrotra

The author works at NIIT Technologies as a senior test engineer. His areas of interest are Java development and automation testing.